



Project Documentation

i Project Title: CRA Compliance Too
Prepared by: Ali Mohammad Hosseini
Date: 30 March 2026

1. Project Overview

Objective

This document specifies the requirement for a tool that is to be used as a self-hosted CRA compliance management software tool designed to help manufacturers of products with digital elements demonstrate conformity with Regulation (EU) 2024/2847 (Cyber Resilience Act).

Scope

This document is intended to provide the information needed for the development and also technical documentation for CRA compliance.

2. Stakeholders

 Stakeholder	 Role	 Description
<u>Project Owner</u>	Developer	Responsible for the planning, designing, and implementation of the project.
<u>Cybersecurity Engineer</u>	End Users	Ensures the product complies with CRA by performing risk assessments, defining secure-by-design requirements, verifying security controls, managing SBOM and third-party component risks, and establishing vulnerability handling processes.
<u>Development Team</u>	End Users	Implements and releases software securely by preventing known vulnerabilities at release time and maintaining transparency and due diligence for all software components through SBOM management.
<u>Product Owner</u>	End Users	Governs the integration of cybersecurity regulatory requirements into the product backlog and ensures all required security documentation and user guidance are complete and traceable.
<u>Lifecycle Manager</u>	End Users	Oversees the product's lifecycle compliance by managing versions, substantial modifications, end-of-support processes, and corrective actions such as recalls or withdrawals when needed.
<u>Legal Team</u>	End Users	Ensures regulatory compliance by preparing, approving, and maintaining the EU Declaration of Conformity and related legal documentation.
<u>Product Management</u>	End Users	Defines and manages the product's security support lifecycle, update strategy, and contractual supply-chain obligations related to cybersecurity.
<u>Admin</u>	Admin	Create roles, control access, back up documents, export documents and configure the tool.

3. Business Requirements

# ID	* Business Requirement Description
<u>BR1</u>	A small organization with no dedicated legal or cybersecurity compliance staff SHALL be able to complete a full CRA compliance cycle without external consultants.
<u>BR2</u>	All compliance artifacts — risk assessments, test reports, SBOMs, DoCs, Annex I mappings — SHALL be managed in one system with full end-to-end traceability.
<u>BR3</u>	The system SHALL prevent placing a product on the market until all critical CRA pre-conditions are provably met, reducing legal exposure for the manufacturer.
<u>BR4</u>	The tool SHALL be deployable on the organization's own infrastructure at a cost proportionate to a micro or small enterprise's budget, with no mandatory third-party SaaS dependency.
<u>BR5</u>	At any point during a product's support period, the system SHALL be able to generate a complete, timestamped, tamper-evident compliance package ready for a Market Surveillance Authority request.
<u>BR6</u>	The system SHALL help organizations remain continuously compliant throughout the full product support period, including vulnerability handling, updates, substantial modifications, retention, and end-of-support obligations.

4. Functional Requirements

# ID	* Functional Requirement Description	⚙ Status	≡ CRA Legal Text
<u>FR1</u>	Users must log in securely with unique credentials.	Not started	
<u>FR2</u>	Access must be controlled through predefined roles and permissions.	Not started	
<u>FR3</u>	All important user actions must be immutably logged.	Not started	

# ID	* Functional Requirement Description	⚙ Status	≡ CRA Legal Text
<u>FR</u> <u>4</u>	The system must manage products in a structured hierarchy.	Not started	
<u>FR</u> <u>5</u>	Each product entity must have unique and searchable identifiers.	Not started	
<u>FR</u> <u>6</u>	The system must capture remote processing elements linked to products.	Not started	
<u>FR</u> <u>7</u>	The system must track FOSS components and their commercial relevance.	Not started	
<u>FR</u> <u>8</u>	The system must guide users in deciding whether a product falls under CRA scope.	Not started	
<u>FR</u> <u>9</u>	The system must classify products as normal, important (class I and II), or critical.	Not started	
<u>FR1</u> <u>0</u>	The system must suggest the correct and possible conformity assessment route.	Not started	
<u>FR1</u> <u>1</u>	The system must support structured cybersecurity risk assessments per product.	Not started	
<u>FR1</u> <u>2</u>	The system must map risk findings to Annex I requirements and evidence.	Not started	
<u>FR1</u> <u>3</u>	Risk assessments must be maintainable throughout the support period.	Not started	
<u>FR1</u> <u>4</u>	The system must translate Annex I obligations into SDL activities and evidence.	Not started	
<u>FR1</u> <u>5</u>	The system must block release when known exploitable vulnerabilities remain.	Not started	
<u>FR1</u> <u>6</u>	The system must support planning and tracking security testing.	Not started	
<u>FR1</u> <u>7</u>	The system must store and link test reports as compliance evidence.	Not started	
<u>FR1</u> <u>8</u>	The system must store machine-readable SBOMs for each release.	Not started	
<u>FR1</u> <u>9</u>	The system must export SBOMs for authority requests.	Not started	

# ID	* Functional Requirement Description	⚙ Status	≡ CRA Legal Text
<u>FR 20</u>	The system must maintain a registry of third-party components.	Not started	
<u>FR 21</u>	The system must check components against vulnerability databases.	Not started	
<u>FR 22</u>	The system must track the update history of third-party components.	Not started	
<u>FR 23</u>	The system must generate notifications for actively exploited vulnerabilities within CRA timelines.	Not started	
<u>FR 24</u>	The system must document the support period and its justification.	Not started	
<u>FR 25</u>	The system must generate support period information for users and packaging.	Not started	
<u>FR 26</u>	The system must track security updates issued during the support period.	Not started	
<u>FR 27</u>	The system must track update availability for the required retention period.	Not started	
<u>FR 28</u>	The system must block market release when critical compliance conditions are unmet.	Not started	
<u>FR 29</u>	The system must maintain version history for product releases and their compliance artifacts.	Not started	
<u>FR 30</u>	The system must guide users in deciding whether a change is substantial.	Not started	
<u>FR 31</u>	The system must preserve evidence traceability across versions.	Not started	
<u>FR 32</u>	The system must generate Annex VII technical documentation from stored data.	Not started	
<u>FR 33</u>	The system must offer a simplified documentation mode for smaller companies.	Not started	
<u>FR 34</u>	The system must generate user information required by Annex II.	Not started	
<u>FR 35</u>	The system must generate and manage the EU Declaration of Conformity.	Not started	

# ID	* Functional Requirement Description	⚙ Status	≡ CRA Legal Text
<u>FR 36</u>	The system must support certification tracking for critical products.	Not started	
<u>FR 37</u>	The system must track non-conformity incidents and corrective actions.	Not started	
<u>FR 38</u>	The system must manage withdrawal of non-compliant products from the market.	Not started	
<u>FR 39</u>	The system must manage product recalls from users.	Not started	
<u>FR 40</u>	The system must provide role-specific dashboards for compliance status.	Not started	
<u>FR 41</u>	The system must generate a complete authority response package.	Not started	
<u>FR 42</u>	The system must enforce CRA retention periods and prevent premature deletion.	Not started	
<u>FR 43</u>	The system must maintain a versioned library of standards and specifications (presumption of conformity).	Not started	
<u>FR 44</u>	The system must map standard clauses to Annex I requirements.	Not started	
<u>FR 45</u>	The system must record deviations from standards and supporting evidence.	Not started	
<u>FR 46</u>	The system must support reusable standards profiles for product types.	Not started	
<u>FR 47</u>	The tool must guide applicability decisions for standards and clauses.	Not started	
<u>FR 48</u>		Not started	
<u>FR 49</u>		Not started	
<u>FR 50</u>		Not started	

5. Non-functional Requirements

# ID	* Security Requirements	☼ Status	≡ Property	≡ Sub-requirements
<u>NFR 1</u>	The system must enforce strong authentication controls.	Not started		
<u>NFR 2</u>	The system must enforce least-privilege authorization.	Not started		
<u>NFR 3</u>	Sensitive data must be protected in transit and at rest.	Not started		
<u>NFR 4</u>	Security-relevant events must be logged with integrity protection.	Not started		
<u>NFR 5</u>	The tool itself must be developed using secure development practices.	Not started		
<u>NFR 6</u>	The system must support encrypted backups and tested recovery.	Not started		
<u>NFR 7</u>	The system must validate inputs and prevent common injection attacks.	Not started		
<u>NFR 8</u>	Administrative and network access must be restricted securely.	Not started		
<u>NFR 9</u>	The tool must be securely configured by default.	Not started		
<u>NFR 10</u>	The tool itself must be CRA complainant.	Not started		

6. User Stories / Use Cases

Use Case 1 — Cybersecurity Engineer

As a Cybersecurity Engineer, I want to create and

Use Case 2 — Cybersecurity Engineer

As a Cybersecurity Engineer, I want to run a pre-release gate that automatically/manually

Use Case 3 — Cybersecurity Engineer

As a Cybersecurity Engineer, I want to create security

version-control a cybersecurity risk assessment linked to a specific product release, so that I can maintain a traceable record of identified threats, vulnerabilities, and their mapping to Annex I Part I requirements.

checks for existence and completeness of required artifacts by CRA.

Required artifacts would be:

- 1- Technical Documentation
- 2- No known exploitable vulnerability

test plans (SAST, DAST, fuzzing, penetration testing) linked to a product release and track their status from planned to complete, so that security verification evidence is always available for technical documentation.

Use Case 1 — Development Team

As a Development Team member, I want to upload or import an SBOM in SPDX or CycloneDX format for each product release so that all software components are transparently documented and linked to the third-party component registry.

Use Case 2 — Development Team

As a Development Team member, I want to be alerted when an exploitable vulnerability is discovered in a component used in a released product so that I can assess impact and initiate a security update without delay, meeting the CRA remediation timelines.

Use Case 3 — Development Team

As a Development Team member, I want to track all security updates issued during the support period — including the CVEs addressed, affected versions, and distribution mechanism.

Use Case 1 — Product Owner

As a Product Owner, I want to map CRA Annex I requirements to engineering requirements in the backlog and track their implementation status per release, so that cybersecurity compliance is fully integrated into our development workflow and remains traceable.

Use Case 2 — Product Owner

As a Product Owner, I want to generate the Annex II user information document from structured product data in the system and export it in PDF or HTML, so that end-user security guidance is always complete and up-to-date at release time.

Use Case 3 — Product Owner

As a Product Owner, I want a role-specific compliance dashboard showing backlog coverage of Annex I requirements and the current Annex II preparation status, so that I can prioritize security tasks and ensure nothing is missing before a release.

Use Case 1 — Lifecycle Manager

As a Lifecycle Manager, I want to document and justify the product's support period using the guided form — covering expected use time, comparable products, and third-party component support periods — so that the

Use Case 2 — Lifecycle Manager

As a Lifecycle Manager, I want the system to automatically notify me 6 months before a product's end-of-support date and generate end-of-support communications for users, so that I can manage the EOS process proactively and in compliance with CRA

Use Case 3 — Lifecycle Manager

As a Lifecycle Manager, I want to use the guided substantial modification workflow to assess whether a product change requires a renewed conformity assessment, and have the outcome logged with justification, so that all version

determination is rationale-driven and defensible under CRA Article requirements.

obligations.

changes are compliantly managed.

Use Case 1 — Legal Team

As a Legal Team member, I want to generate a draft EU Declaration of Conformity from structured product and conformity assessment data, apply a digital signature, and lock the document to prevent post-signature edits, so that the DoC is legally valid and tamper-evident.

Use Case 2 — Legal Team

As a Legal Team member, I want to generate a one-click Market Surveillance Authority response package containing the technical documentation, DoC, SBOM, and test reports as a ZIP archive with a full audit trail of the disclosure, so that authority requests can be fulfilled quickly and completely.

Use Case 3 — Legal Team

As a Legal Team member, I want to receive required information for contracting topics, such as support period, tailor-made products, security update mechanisms, and required resources for supporting during support period.

Use Case 1 — Product Management

As a Product Manager, I want to document and justify the product security support lifecycle —

Use Case 2 — Product Management

As a Product Manager, I want to manage supply chain contracts by using clause templates for cybersecurity obligations and linking them to

Use Case 3 — Product Management

As a Product Manager, I want a dashboard view showing all products with open support period compliance issues or

including the type of security support offered and the end date — and have this information automatically included in the Annex II user information output, so that users and regulators have clear, accessible support commitment data.

specific suppliers and components, so that contractual due diligence requirements under CRA are consistently enforced.

approaching end-of-support dates, so that I can make timely decisions on update strategy, end-of-life planning, and communication.

Use Case 1 — Admin

As an Admin, I want to create user accounts, assign one or multiple predefined roles (Cybersecurity Engineer, Legal Team, etc.), and enforce role-based access control across all system modules, so that each user accesses only the data and functions relevant to their responsibilities.

Use Case 2 — Admin

As an Admin, I want to configure automated daily encrypted backups with a 90-day retention period and test restore procedures, so that all compliance documentation remains recoverable in case of system failure or ransomware.

Use Case 3 — Admin

As an Admin, I want to export and archive compliance documents and query the immutable audit log by date range, user, or action type, so that I can support internal audits, regulatory inspections, and data retention enforcement over the required 10-year period.

7. Assumptions and Constraints

Assumptions

- The organization might have different documentation systems, such as Confluence, OneDrive, Jira, etc. Thus, the various resources might be referenced properly
- The tool intended to be used by organizations that have less human and technical resources. Therefore, roles can be overtaken by less people.
- The tool itself must be CRA compliant. It will receive security updates.

Constraints

- CRA interpretation is constantly changing. Therefore, the requirement and design is limited and subjected to future changes.
- Due to the nature of information stored in the system which are very sensitive and confidential, only a local implementation is considered and not Cloud.
- The first implementation does not consider horizontal and vertical standards as they are still under preparation.

8. Acceptance Criteria

# ID	* Acceptance Criteria
<u>AC1</u>	
<u>AC2</u>	
<u>AC3</u>	
<u>AC4</u>	
<u>AC5</u>	
<u>AC6</u>	
<u>AC7</u>	
<u>Untitled</u>	

9. Appendix

Tools planned on using:

- Frontend: vuejs, HTML
- Backend: FastAPI, Python
- Database: Postgres
- Hosting: GitHub
- IDE: Visual Studio Code

Threat Modelling and Risk Assessment

CRA Essential Requirements

FR7 (5).

FR7 (3).

FR7 (4).

FR7 (5).